

ZERO TRUST ARCHITECTURE

Membangun Pertahanan Berbasis Identitas, Postur Perangkat, dan Visibilitas SOC Tanpa Perimeter.

Disusun Oleh: **Rizki Angga Pratama**
L2 SOC Analyst

HAK CIPTA & DISCLAIMER

Zero Trust Architecture (ZTA) in Practice
Edisi Enterprise (50 Halaman)

Disusun oleh: Rizki Angga Pratama, S. Kom, C. Pro

Dokumen ini merupakan panduan strategis dan teknis yang merinci transformasi arsitektur keamanan perusahaan dari model *Castle-and-Moat* tradisional menuju model verifikasi berkelanjutan *Zero Trust*.

> **Catatan Operasional:**
> Konsep *Zero Trust* yang dibahas dalam dokumen ini didasarkan pada kerangka kerja **NIST SP 800-207**. Implementasi praktisnya mencakup konfigurasi alat dari berbagai vendor (seperti Okta, Azure AD, CrowdStrike, dan Zscaler) yang ditulis sebagai ilustrasi rekayasa (engineering context) bagi Security Operations Center (SOC).

Filosofi Desain:
Dirancang menggunakan estetika *Dark Mode* dengan palet warna *Deep Violet* dan *Electric Cyan*, merepresentasikan garis tak kasatmata dari kriptografi, identitas digital modern, dan batas proksi yang menggantikan tembok fisik pusat data masa lalu.

© 2026 Hak cipta dilindungi undang-undang. Dokumen referensi pelatihan SOC.

KATA PENGANTAR

Keamanan siber korporat selama bertahun-tahun hidup dalam ilusi geografis. Kita membangun *Firewall* raksasa di tepi jaringan kantor, lalu secara implisit mempercayai siapa pun yang berhasil masuk ke dalam. Model *Castle and Moat* (Kastil dan Parit) ini bekerja dengan baik saat semua data kita berada di dalam gedung, dan semua karyawan duduk di meja mereka.

Namun, awan (*Cloud*) telah menguapkan parit tersebut. Pandemi memaksa tenaga kerja kita keluar dari kastil. Hari ini, data Anda berada di AWS, aplikasi Anda di Salesforce, dan karyawan Anda mengaksesnya dari jaringan kafe publik menggunakan laptop pribadi.

Di dunia tanpa batas ini, **Zero Trust Architecture (ZTA)** bukan sekadar buzzword pemasaran; ia adalah satu-satunya instrumen keselamatan. ZTA membunuh konsep "Kepercayaan Implisit" (Implicit Trust). Ia memindahkan perimeter keamanan dari infrastruktur jaringan menuju entitas individu: Identitas dan Perangkat.

Buku 50 halaman ini dirancang bagi para Insinyur Keamanan (*Security Engineers*) dan Analis SOC. Kita akan membedah bagaimana *Identity Provider* (IdP) mengambil alih peran dinding *firewall*, bagaimana proksi ZTNA menggantikan VPN yang rentan, dan bagaimana SOC merancang aturan KQL untuk mendeteksi Adversary-in-the-Middle (AiTM) yang mencoba menembus arsitektur modern ini.

Mari kita rancang ulang pertahanan ini dari nol.

— Rizki Angga Pratama

Author

DAFTAR ISI (1/2)

BAGIAN I: Runtuhnya Perimeter Tradisional

Bab 1.1 Ilusi Keamanan Castle & Moat Hlm. 7

Bab 1.2 Definisi Resmi NIST SP 800-207 Hlm. 8

Bab 1.3 Asumsikan Telah Dibobol (Assume Breach) Hlm. 9

Bab 1.4 Control Plane vs Data Plane Hlm. 10

Bab 1.5 Komponen Policy Engine (PE) & PDP Hlm. 11

Bab 1.6 Trust Algorithm: Bagaimana Keputusan Dibuat Hlm. 12

BAGIAN II: Identitas sebagai Perimeter Baru (IAM)

Bab 2.1 Evolusi Identity Access Management Hlm. 14

Bab 2.2 SSO & Standar SAML/OIDC Hlm. 15

Bab 2.3 Kematian Kata Sandi (Passwordless) Hlm. 16

Bab 2.4 Kelemahan MFA Tradisional (OTP/SMS) Hlm. 17

Bab 2.5 Phishing-Resistant MFA (FIDO2 & WebAuthn) Hlm. 18

Bab 2.6 Conditional Access Policies (CAP) Hlm. 19

Bab 2.7 Sinyal Risiko Pengguna (User Risk) Hlm. 20

Bab 2.8 Mendeteksi Anomali Impossible Travel Hlm. 21

Bab 2.9 Proteksi terhadap Serangan AiTM Hlm. 22

DAFTAR ISI (2/2)

BAGIAN III: Postur Perangkat & ZTNA

Bab 3.1 ZTNA vs VPN Tradisional Hlm. 24

Bab 3.2 Konsep Dark Cloud & Reverse Proxy Hlm. 25

Bab 3.3 Mengukur Device Posture (Health Score) Hlm. 26

Bab 3.4 Integrasi Telemetri EDR ke PDP Hlm. 27

Bab 3.5 Manajemen Perangkat (MDM / Intune) Hlm. 28

Bab 3.6 Agent vs Agentless ZTNA Deployment Hlm. 29

Bab 3.7 Memfasilitasi Akses BYOD yang Aman Hlm. 30

Bab 3.8 Isolasi Browser (Remote Browser Isolation) Hlm. 31

Bab 3.9 DLP pada Lapisan Proksi ZTA Hlm. 32

BAGIAN IV: Micro-Segmentation & Network

Bab 4.1 Menghentikan Lateral Movement Hlm. 34

Bab 4.2 East-West vs North-South Traffic Hlm. 35

Bab 4.3 Host-Based Firewalls Terpusat Hlm. 36

Bab 4.4 Software Defined Perimeter (SDP) Hlm. 37

Bab 4.5 Kepercayaan Workload-to-Workload Hlm. 38

Bab 4.6 Pengamanan API di ZTA Hlm. 39

Bab 4.7 Service Mesh & mTLS di Kubernetes Hlm. 40

Bab 4.8 Network Access Control (NAC) Modern Hlm. 41

BAGIAN V: Visibilitas SOC & SOAR Automation

Bab 5.1 Blind Spots Baru di Era ZTA Hlm. 43

Bab 5.2 SIEM Ingestion untuk Identity Logs Hlm. 44

Bab 5.3 KQL: Mendeteksi MFA Fatigue Attack Hlm. 45

Bab 5.4 KQL: Mendeteksi Session Token Theft Hlm. 46

Bab 5.5 Continuous Evaluation Mechanism Hlm. 47

Bab 5.6 SOAR: Otomatisasi Session Revocation Hlm. 48



BAGIAN I

Runtuhnya Perimeter Tradisional
& Fondasi Zero Trust

BAB 1: FONDASI ARSITEKTUR

1.1 Ilusi Keamanan Castle & Moat

Secara historis, departemen TI membangun jaringan mereka layaknya sebuah kastil abad pertengahan. Mereka berinvestasi miliaran rupiah pada "parit" berupa *Next-Generation Firewall* (NGFW), *Intrusion Prevention System* (IPS), dan perlengkapan VPN raksasa di tepi batas jaringan mereka.

Asumsi dasarnya sederhana namun fatal: **Semua yang berada di luar jaringan (Internet) adalah musuh, dan semua yang berada di dalam jaringan (LAN Korporat) adalah kawan.**

Begitu seorang penyerang berhasil mencuri kata sandi VPN seorang karyawan, atau menyuap staf internal, mereka melewati parit tersebut. Sesampainya di dalam, penyerang menemui hamparan padang rumput yang datar tanpa pengawasan. Mereka dapat melakukan *Ping* ke peladen *Database*, mengakses *File Share*, dan mengeksekusi *Lateral Movement* tanpa ada yang mempertanyakan siapa mereka lagi, karena mereka memiliki "IP Internal". Inilah titik kegagalan utama dari model jaringan tradisional.

1.2 Definisi Resmi NIST SP 800-207

Untuk menertibkan vendor yang menggunakan *Zero Trust* sekadar sebagai strategi pemasaran, Institut Standar dan Teknologi Nasional AS (NIST) menerbitkan kerangka kerja **SP 800-207**.

Menurut NIST, Zero Trust Architecture (ZTA) adalah rencana keamanan siber yang memanfaatkan konsep *Zero Trust* untuk memfokuskan perlindungan pada **sumber daya** (data/aplikasi), bukan pada **segmen jaringan**. Premis dasarnya menyatakan bahwa kepercayaan tidak pernah diberikan secara implisit berdasarkan lokasi fisik atau jaringan (seperti IP kantor atau koneksi VPN).

> **Tiga Poin Kunci NIST ZTA:**
> 1. Seluruh sumber daya, bagaimanapun lokasinya, diklasifikasikan sebagai sumber daya yang dapat diakses.
> 2. Komunikasi ke sumber daya harus diamankan terlepas dari letak jaringan (semuanya dienkripsi *end-to-end*).
> 3. Akses ke sumber daya individu diberikan secara spesifik per sesi (*per-session basis*).

1.3 Asumsikan Telah Dibobol (Assume Breach)

Pergeseran pola pikir paling radikal dalam ZTA adalah **Assume Breach**. *Security Engineer* tidak lagi merancang sistem dengan pertanyaan: *"Bagaimana cara mencegah peretas masuk?"* Melainkan: *"Peretas sudah berada di dalam jaringan kita saat ini, bagaimana kita membatasi kerusakan yang bisa mereka buat?"*

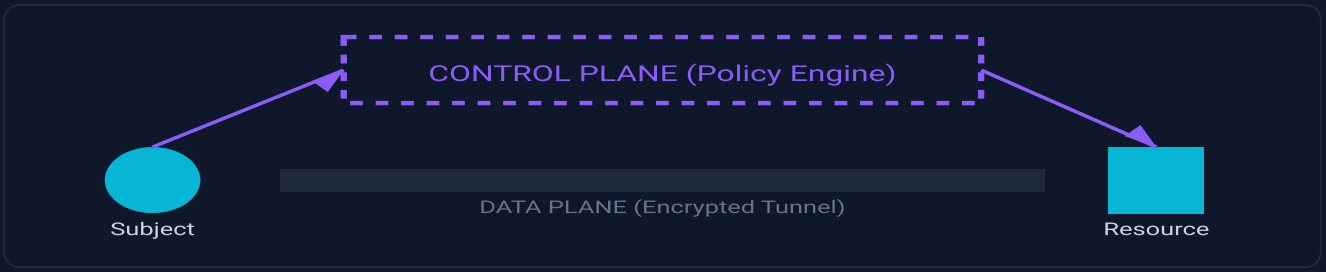
Jika kita mengasumsikan jaringan telah dikompromikan:

- Kita tidak akan pernah mempercayai alamat IP lokal (192.168.x.x).
- Kita akan menuntut setiap aplikasi (bahkan aplikasi internal HRD) untuk tetap meminta autentikasi yang kuat.
- Kita akan mengenkripsi lalu lintas jaringan antar-peladen (*East-West Traffic*), karena kita asumsikan peretas sedang menyadap kabel jaringan (*packet sniffing*) di dalam *Data Center* kita sendiri.

Prinsip ini memaksa arsitektur untuk bersifat paranoid secara permanen dan menempatkan pos pemeriksaan (*Checkpoints*) mikro di setiap persimpangan data.

1.4 Control Plane vs Data Plane

Arsitektur ZTA memisahkan jaringan menjadi dua lapisan logis yang tidak boleh bersentuhan langsung: **Control Plane** (Bidang Kontrol) dan **Data Plane** (Bidang Data).



Control Plane adalah otak pengambil keputusan (seperti IdP/Okta). Pengguna dan perangkat berkomunikasi dengan bidang ini untuk meminta izin. **Data Plane** adalah jalan tol tempat data sesungguhnya mengalir menuju aplikasi, dan jalan tol ini hanya dibuka jika *Control Plane* memberikan kunci spesifik. Peretas di *Data Plane* tidak dapat menembus atau merekayasa keputusan di *Control Plane*.

1.5 Komponen Policy Engine (PE) & PDP

Otak dari ZTA menurut NIST dibagi menjadi mesin pengambil keputusan dan titik penegakan hukum.

- **Policy Engine (PE):** Algoritma utama yang menganalisis seluruh sinyal masuk. Ia mempertimbangkan risiko identitas, kesehatan EDR, lokasi IP, dan jam akses. Hasil akhirnya berbentuk biner logis: "Izinkan" atau "Tolak".
- **Policy Administrator (PA):** Mengeksekusi keputusan PE. Ia yang bertugas membuat, mematikan, atau memodifikasi terowongan komunikasi ke target.
- **Policy Enforcement Point (PEP):** Penjaga pintu logis (biasanya berupa Proksi ZTNA atau gerbang *Gateway* mikro). PEP berinteraksi langsung dengan pengguna. Ia meneruskan permintaan ke PA, lalu membuka/menutup gerbang Data Plane sesuai perintah.

Secara praktis di industri, PE dan PA sering kali digabung ke dalam satu produk (seperti layanan **Policy Decision Point / PDP** berbasis *Cloud* milik vendor ZTNA).

1.6 Trust Algorithm: Bagaimana Keputusan Dibuat

Mesin kebijakan (PE) tidak bertindak secara acak; ia beroperasi berdasarkan **Algoritma Kepercayaan (Trust Algorithm)** yang telah dikonfigurasi oleh Arsitek SOC.

Algoritma ini bisa berbasis *Kriteria (Criteria-based)* atau berbasis *Skor (Score-based)*.

```
# Pseudo-Logic of Score-Based Trust Algorithm function evaluate_trust(user, device, resource) {
base_score = 100 if user.mfa_method == "SMS" then base_score -= 20 if device.edr_status == "disabled"
then base_score -= 50 if user.location == "HighRisk_Country" then base_score -= 40 if
resource.classification == "CONFIDENTIAL" and base_score < 85 { return "DENY_ACCESS" } else { return
"GRANT_SESSION_1_HOUR" } }
```

Dalam pendekatan modern, PE juga menyuntikkan *Threat Intelligence* eksternal dan *Machine Learning* ke dalam perhitungan ini untuk mendeteksi vektor yang tidak terlihat oleh aturan (*rules*) statis.



BAGIAN II

Identitas sebagai Perimeter Baru
(IAM & Conditional Access)

BAB 2: MANAJEMEN IDENTITAS

2.1 Evolusi Identity Access Management (IAM)

Jika jaringan fisik tidak bisa lagi dipercaya, maka otorisasi bergeser ke lapisan aplikasi dan orang yang menggunakannya. **Identity Access Management (IAM)** berevolusi dari sekadar peladen penyimpan sandi (seperti *Microsoft Active Directory / AD* lokal) menjadi jembatan proksi otorisasi global (seperti *Entra ID* atau *Okta*).

Pada model lama, karyawan harus menghafal puluhan kata sandi untuk berbagai aplikasi berbeda. Hal ini melahirkan kebiasaan buruk: menggunakan ulang sandi yang sama (*Password Reuse*) di semua tempat. Saat salah satu aplikasi forum pihak ketiga diretas, peretas dapat mencoba sandi tersebut ke portal email perusahaan (*Credential Stuffing*) dan berhasil masuk.

Di ekosistem Zero Trust, IAM bertindak sebagai **IdP (Identity Provider) Sentral**. Karyawan hanya memiliki satu identitas absolut. Semua aplikasi pihak ketiga tidak diizinkan memiliki basis data sandi sendiri; mereka harus tunduk dan mendelegasikan tantangan autentikasi kepada IdP Sentral ini.

2.2 SSO & Standar SAML/OIDC

Mendelegasikan autentikasi ke pusat dicapai melalui teknologi **Single Sign-On (SSO)** yang didukung oleh protokol federasi seperti *SAML 2.0* (Security Assertion Markup Language) dan *OpenID Connect (OIDC)*.

Saat karyawan mengetik `app.salesforce.com`, Salesforce menyadari bahwa pengguna ini belum diautentikasi. Salesforce (bertindak sebagai *Service Provider/SP*) akan membuat token SAML Request dan memantulkan (*redirect*) *browser* pengguna ke URL Okta (sebagai IdP).

Di Okta, verifikasi ZTA terjadi (cek sandi, MFA, postur EDR). Jika berhasil, Okta memberikan tiket digital berstempel kriptografi (SAML Assertion) ke *browser*, yang kemudian diserahkan kembali ke Salesforce. Salesforce memvalidasi tanda tangan digital tiket tersebut, dan memberikan akses.

Keuntungannya: Peretas yang menargetkan *Salesforce* tidak akan pernah mendapatkan *Hash Password* pengguna Anda, karena Salesforce secara harfiah tidak pernah melihat atau menyimpan kata sandi pengguna.

2.3 Kematian Kata Sandi (Passwordless)

Meskipun menggunakan SSO, jika metode utamanya masih berupa *Username* dan *Password*, arsitektur tersebut masih rentan terhadap *Phishing* (rekayasa sosial). Solusi *Zero Trust* modern mengadopsi autentikasi **Passwordless**.

Dalam autentikasi *Passwordless*, pengguna tidak perlu mengetikkan apapun. Saat mereka masuk ke SSO, IdP akan mengirimkan tantangan kriptografi asimetris (*Public/Private Key*) ke perangkat pengguna (seperti aplikasi Microsoft Authenticator atau pemindai sidik jari *Windows Hello for Business*).

Kunci pribadi (*Private Key*) tertanam aman di dalam perangkat keras *Trusted Platform Module* (TPM) milik laptop/ponsel. Ia tidak bisa diekspor atau dicuri oleh *malware stealer*. Ini membunuh ancaman *Credential Stuffing* dan *Keyloggers* secara instan, karena kata sandi yang bisa dicuri sudah tidak ada lagi.

2.4 Kelemahan MFA Tradisional (OTP/SMS)

Banyak perusahaan merasa aman setelah mengaktifkan *Multi-Factor Authentication (MFA)*. Namun, *Zero Trust* membedakan kualitas alat MFA. MFA berbasis SMS atau kode angka OTP (Google Authenticator) **sangat rentan** terhadap intersepsi proksi (*Adversary-in-the-Middle / AiTM*).

> **Anatomi Serangan AiTM Phishing:**
> 1. Peretas membuat situs palsu `login.microsOft.com` (huruf 'o' diganti '0').
> 2. Karyawan memasukkan *Username* dan *Password*. Situs peretas otomatis meneruskannya ke Microsoft asli.
> 3. Microsoft asli memicu Google Authenticator. Karyawan melihat aplikasi di HP-nya dan mengetikkan `123456` di situs peretas.
> 4. Situs peretas menyerahkan kode itu ke Microsoft asli, lalu mencuri **Session Cookie** yang dihasilkan.

Dalam skenario di atas, sistem MFA bekerja sempurna, namun pengguna tertipu karena memberikan kode OTP tersebut kepada mesin perantara. ZTA membutuhkan metode yang kebal terhadap tipuan manusia.

2.5 Phishing-Resistant MFA (FIDO2)

Jawaban untuk mengalahkan AiTM *Phishing* adalah penerapan **Phishing-Resistant MFA** menggunakan standar **FIDO2 / WebAuthn** (misalnya perangkat *Hardware Security Key* seperti YubiKey, atau *Passkeys* Apple/Google).

FIDO2 bekerja dengan mengikat tantangan autentikasi pada **Nama Domain Asli (Origin Domain)** dari *browser*.

Jika pengguna ditipu untuk masuk ke `login.micros0ft.com`, *browser* akan berkomunikasi dengan *YubiKey* dan meminta tanda tangan digital untuk domain palsu tersebut. Saat tanda tangan diserahkan ke Microsoft asli, peladen Microsoft akan menolaknya dengan keras: *"Tanda tangan kripto ini diklaim untuk domain micros0ft.com, bukan untuk domain asli saya. Sesi Ditolak!"*

Dengan FIDO2, tidak ada kode angka yang bisa disalin oleh manusia, dan verifikasi domain dilakukan secara matematis oleh protokol *WebAuthn*. Ini adalah standar emas identitas di *Zero Trust*.

2.6 Conditional Access Policies (CAP)

Conditional Access Policies (Kebijakan Akses Bersyarat) adalah perwujudan dari *Policy Engine* (PE). Di Microsoft Entra ID atau Okta, CAP dieksekusi setelah pengguna memasukkan kata sandi dan MFA yang benar, namun sebelum akses diberikan.

Kondisi yang dinilai meliputi:

- **Network Location:** Apakah permintaan berasal dari Daftar IP Perusahaan, atau dari VPN negara asing yang mencurigakan (*Tor Exit Node*)?
- **Device State:** Apakah perangkat mematuhi (*Compliant*) kebijakan Intune MDM? Apakah ia memiliki enkripsi BitLocker?
- **Client App:** Apakah akses menggunakan aplikasi *Browser* yang disetujui, atau klien IMAP/POP3 lawas yang tidak mendukung MFA (*Legacy Authentication*)?

Kombinasi CAP menciptakan logika mikro: *"Jika pengguna HR mengakses aplikasi Gaji dari luar kantor, WAJIBKAN FIDO2. Jika dari dalam kantor dan dari Laptop yang dikelola, IZINKAN akses mulus (SSO)."*

2.7 Sinyal Risiko Pengguna (User Risk)

Sistem IAM yang cerdas tidak hanya membaca aturan statis, mereka mengadopsi *Machine Learning* untuk menilai **Risiko Pengguna (User Risk)** dan **Risiko Masuk (Sign-in Risk)**.

User Risk dihitung secara latar belakang (*offline*). IdP besar seperti Microsoft terus memindai kumpulan kebocoran data di pasar gelap (*Dark Web*). Jika sistem mendapati kombinasi `rizki@perusahaan.com` beserta kata sandinya baru saja diunggah ke forum peretas, maka *User Risk* akun tersebut otomatis ditingkatkan ke level **High** (Tinggi).

Saat karyawan tersebut mencoba *login* esok paginya, PE ZTA akan melihat flag *High Risk* ini, memblokir akses ke aplikasi, dan secara otomatis memaksanya melakukan **Self-Service Password Reset (SSPR)** yang dilindungi MFA sebelum ia dapat melanjutkan pekerjaannya.

2.8 Mendeteksi Impossible Travel

Salah satu deteksi anomali identitas paling klasik dan efektif dalam ZTA adalah **Impossible Travel (Perjalanan Tidak Mungkin)**.

Skenario: Pengguna A berhasil *login* dari Jakarta (IP Indihome) pada pukul 08:00 WIB. Tiga puluh menit kemudian, akun Pengguna A yang sama (dengan sandi yang benar) berhasil *login* ke aplikasi M365 dari Frankfurt, Jerman (IP AWS).

Secara fisika, mustahil bagi manusia untuk terbang dari Jakarta ke Jerman dalam 30 menit. *Policy Engine* mendeteksi anomali perhitungan kecepatan (*Velocity Calculation*) ini dan langsung menaikkan *Sign-In Risk* menjadi **High**. CAP secara instan akan memblokir *login* dari Jerman tersebut karena probabilitas kredensial telah bocor sangat tinggi.

Catatan untuk SOC: Peringatan ini sering menghasilkan *False Positive* jika karyawan mengaktifkan layanan VPN pribadi (seperti NordVPN/ExpressVPN) di *browser* mereka tanpa sepengetahuan kantor.

2.9 Proteksi AiTM via Session Binding

Meskipun FIDO2 melindungi dari serangan AiTM di fase autentikasi awal, peretas tingkat lanjut telah beralih ke mencuri kuki (*cookie*) fisik (menggunakan *Malware InfoStealer*) dari *browser* korban. Kuki sesi (*Session Cookie*) ini bisa digunakan untuk membajak akun (*Session Hijacking*) dari komputer manapun.

Lapisan pertahanan ZTA selanjutnya adalah **Token Binding** (atau *Continuous Access Evaluation / CAE*). Alih-alih kuki dibiarkan bebas, kuki tersebut "diikat" (*bound*) secara kriptografik ke perangkat keras klien atau ke *IP address* spesifik saat sesi pertama kali dibuat.

Ketika peretas mengekstrak kuki ini dan mencoba menyuntikkannya (*Inject*) ke *browser* mereka di Rusia, *Gateway* ZTNA akan melihat ketidakcocokan: *"Kuki ini sah, tetapi diklaim untuk Perangkat A. Anda menyajikannya dari Perangkat B. Sesi Ditolak!"*

Inilah yang membuat arsitektur *Zero Trust* menjadi mimpi buruk operasional bagi peretas modern.



BAGIAN III

Postur Perangkat, ZTNA, &
Kematian VPN

BAB 3: POSTUR PERANGKAT & ZTNA

3.1 ZTNA vs VPN Tradisional

Virtual Private Network (VPN) adalah peninggalan era *Castle and Moat*. Ia memberikan pengguna sebuah IP pada *Subnet* perusahaan, menjadikan *laptop* karyawan secara virtual berada di dalam gedung kantor. Masalahnya: Jika laptop itu terinfeksi *Ransomware*, *malware* tersebut bebas menyebar (*worm*) ke seluruh peladen kantor melalui terowongan VPN.

Zero Trust Network Access (ZTNA) menyelesaikan krisis ini dengan pendekatan aplikasi-sentris. ZTNA tidak menghubungkan jaringan ke jaringan (*Network-to-Network*), melainkan menghubungkan pengguna ke aplikasi individu (*User-to-App*).

Dalam ZTNA, pengguna yang membutuhkan akses ke Aplikasi Keuangan tidak akan pernah diberikan akses jaringan (*Routing*) ke Aplikasi SDM. Pemisahan ekstrem ini mematikan taktik pergerakan lateral (*Lateral Movement*) yang menjadi inti dari sebagian besar eksploitasi APT.

3.2 Konsep Dark Cloud & Reverse Proxy

Arsitektur ZTNA modern mengadopsi model **Dark Cloud (Proksi Terbalik)**. Daripada aplikasi internal Anda membuka *port* pendengar (*Listener Port 443*) yang terekspos ke internet publik, Anda memasang "Konektor" kecil di samping aplikasi Anda.

Konektor ini akan melakukan koneksi keluar (*Outbound Connection*) ke layanan *Cloud Broker* ZTNA (seperti Zscaler Private Access atau Cloudflare Tunnel). Koneksi keluar ini tidak memerlukan *Inbound Port Forwarding* di *Firewall* perusahaan.

> **Manfaat Keamanan Invisibility (Ketidaktampakan):**
> Karena tidak ada IP publik yang mendengarkan permintaan (*listening*), para penyerang, *botnet*, atau *scanner* seperti Shodan **tidak dapat menemukan** aplikasi internal Anda. Aplikasi Anda secara fisik hilang dari radar internet (*Dark*), dan hanya dapat diakses melalui portal Broker ZTNA oleh pengguna yang telah diautentikasi dengan benar.

3.3 Mengukur Device Posture (Health Score)

Prinsip ZTA mengharuskan kita mengukur "Kesehatan" perangkat sebelum mengizinkan koneksi. Mengautentikasi pengguna saja tidak cukup; kredensial bisa diketik di komputer umum (*warnet*) yang penuh *Keylogger*.

Untuk mengakses Data Kritis perusahaan, arsitektur ZTA (via *Conditional Access*) akan menanyakan postur perangkat (*Device Posture*). Kondisi ini dinilai oleh agen klien ZTNA atau EDR yang terpasang di *laptop* karyawan:

- Apakah perangkat memiliki Enkripsi *Disk* Penuh (BitLocker / FileVault)?
- Apakah *Firewall* OS aktif?
- Apakah *patch* OS minimal Windows 10 Versi 22H2?
- Apakah perangkat bebas dari proses biner jahat yang terdeteksi?

Jika salah satu kriteria ini gagal, sesi SSO pengguna tidak akan diberikan tiket akses, atau mereka hanya akan diberikan akses *Read-Only* ke aplikasi berisiko rendah.

3.4 Integrasi Telemetri EDR ke PDP

Kolaborasi keamanan (*Security Interoperability*) adalah jantung implementasi *Zero Trust* tingkat lanjut. EDR (seperti CrowdStrike) tidak hanya bertugas memblokir *malware*, tetapi juga bertindak sebagai Penilai Risiko Perangkat (*Device Risk Assessor*).

```
// Simulasi Pertukaran API (EDR ke ZTNA Gateway) POST https://zta-broker.com/api/v1/device/status
Content-Type: application/json { "host_id": "machine-xyz-99", "risk_score": "CRITICAL", // EDR
mendeteksi injeksi LSASS! "timestamp": "2026-10-25T12:00:00Z" }
```

Saat EDR mendeteksi aktivitas mencurigakan, ia bukan hanya mengkarantina berkas, tetapi segera membocorkan *API Payload* "Risk = CRITICAL" ke *Gateway ZTNA* dan *Identity Provider* (Okta/Entra). Dalam mili-detik, ZTNA memutuskan (*Terminate*) semua sesi aktif (seperti sesi unduhan *Sharepoint* yang sedang berjalan), memutus eksfiltrasi data bahkan sebelum analis SOC sempat melihat tiket insiden.

3.5 Manajemen Perangkat (MDM / Intune)

Menilai kesehatan memerlukan kewenangan (*Authority*). Perusahaan membutuhkan sistem **Mobile Device Management (MDM)** seperti Microsoft Intune, Jamf (untuk macOS), atau VMware Workspace ONE untuk menegakkan konfigurasi keamanan.

Dalam *Zero Trust*, perangkat dibagi menjadi dua kelompok: **Managed** (Dikelola Perusahaan) dan **Unmanaged** (Pribadi/BYOD).

Perangkat yang dikelola (*Managed*) memiliki Sertifikat Klien (*Client Certificate*) yang ditanamkan secara rahasia oleh MDM ke dalam memori *Trusted Platform Module* (TPM) laptop tersebut. Saat ZTNA mengautentikasi pengguna, ia juga secara senyap memeriksa keberadaan sertifikat ini. Hal ini menggagalkan peretas yang mencoba masuk menggunakan *password* curian dari komputer mereka sendiri, karena mereka tidak memiliki Sertifikat Klien perusahaan.

3.6 Agent vs Agentless ZTNA

Implementasi ZTNA memiliki dua pendekatan penggelaran utama, tergantung pada pengguna akhir yang dilayani.

FITUR	AGENT-BASED ZTNA (DENGAN APLIKASI)	AGENTLESS ZTNA (VIA BROWSER WEB)
Pengguna Target	Karyawan Internal / Perangkat *Managed*.	Kontraktor, Pihak Ketiga, Perangkat BYOD.
Cara Kerja	Klien perangkat lunak (agen) diinstal di OS. Mengarahkan (*tunneling*) semua lalu lintas TCP/UDP aplikasi (SSH, RDP, SQL).	Tanpa instalasi. Pengguna *login* via portal web. Hanya mendukung aplikasi berbasis HTTP/HTTPS (Web Apps).
Postur (Posture)	Sangat dalam (Dapat mengecek versi *registry* dan EDR).	Terbatas (Hanya bisa mengecek ekstensi *Browser*, IP, dan OS dasar).

Perusahaan berskala menengah ke atas (*Enterprise*) umumnya menggunakan hibrida: Agen untuk staf penuh, dan Portal *Agentless* untuk mitra vendor yang hanya memerlukan akses baca (*read-only*) ke dasbor spesifik.

3.7 Memfasilitasi Akses BYOD yang Aman

Bring Your Own Device (BYOD) (Menggunakan laptop/ponsel pribadi) adalah mimpi buruk bagi keamanan tradisional. Anda tidak bisa memaksa instalasi EDR perusahaan di laptop *gaming* pribadi milik karyawan.

Zero Trust memecahkan ini dengan kebijakan adaptif (*Adaptive Policies*). ZTNA memungkinkan pengguna BYOD (perangkat *Unmanaged*) untuk masuk secara sah (jika autentikasi MFA berhasil), namun ZTNA membatasi **tingkat izinnya** di dalam aplikasi.

> **Contoh Adaptive BYOD:**
> Saat mengakses Microsoft 365 Outlook dari perangkat kantor (*Managed*), karyawan dapat mengunduh lampiran Excel ke *Hard Disk*.
> Saat mengakses M365 dari perangkat rumah (*BYOD/Unmanaged*), ZTNA Gateway mencegat sesi tersebut: Karyawan masih dapat membaca email, namun **Tombol Unduh (Download) dimatikan secara paksa** (dihilangkan dari antarmuka Web).

3.8 Remote Browser Isolation (RBI)

Sebagai evolusi dari penanganan BYOD dan pencegahan *malware*, konsep ZTA sering digabungkan dengan **Remote Browser Isolation (RBI)**.

Saat karyawan (atau kontraktor pihak ketiga) membuka portal internal yang super sensitif (seperti aplikasi Intranet HRD), portal tersebut tidak dimuat di *browser* Chrome fisik milik karyawan. Sebaliknya, aplikasi dimuat di kontainer *Docker* sekali pakai (*ephemeral*) yang berjalan di peladen awan ZTNA.

Yang dikirim ke layar komputer karyawan hanyalah **aliran piksel gambar (Pixel Stream)**—mirip dengan menonton video YouTube atau bermain *Cloud Gaming*. Karena tidak ada kode HTML, *JavaScript*, atau DOM nyata yang dikirim ke komputer pengguna, segala bentuk *Keylogger* lokal atau upaya penyedotan data oleh ekstensi *Browser* jahat di komputer klien akan sepenuhnya gagal.

3.9 DLP pada Lapisan Proksi ZTA

Data Loss Prevention (DLP) di era lawas dilakukan oleh mesin raksasa di gerbang utama pusat data. Dalam ZTA, DLP dipindahkan ke *Cloud Edge* (bersemayam bersama ZTNA/CASB).

Karena arsitektur ZTA/CASB menghentikan (*terminate*) koneksi SSL (menjadi *Man-in-the-Middle* yang sah bagi koneksi korporat), mesin DLP dapat membaca teks dalam dokumen (*Plaintext*) yang diunggah ke Google Drive atau aplikasi internal.

Jika seorang pengguna yang diautentikasi secara sah (dengan skor ZTA 100) mencoba mengunggah berkas Excel berisi ratusan nomor Kartu Kredit (PCI-DSS) ke akun *Dropbox* pribadi mereka, PEP (*Policy Enforcement Point*) ZTA akan membaca regex nomor kartu kredit tersebut, memblokir pengunggahan secara *real-time*, dan menyalakan *Alert Critical* di dasbor SIEM milik SOC.



BAGIAN IV

Micro-Segmentation &
Komunikasi Jaringan

BAB 4: NETWORK & MICRO-SEGMENTATION

4.1 Menghentikan Lateral Movement

Sejauh ini, kita telah membahas cara melindungi pengguna yang masuk (*User-to-App*). Namun ZTA juga menuntut perlindungan komunikasi di dalam pusat data itu sendiri (*App-to-App* atau *Server-to-Server*).

Dalam model klasik (VLAN besar), jika satu peladen *Web Front-End* diretas karena eksploitasi kode (*RCE*), peretas tersebut dapat memindai (*scan*) seluruh IP di VLAN tersebut dan menyerang peladen *Database Back-End* secara langsung tanpa halangan. Ini adalah taktik pergerakan lateral (*Lateral Movement*).

ZTA menyelesaikan ini menggunakan **Micro-segmentation** (Segmentasi Mikro). Daripada memisahkan jaringan berdasarkan departemen (misal: "VLAN Server Produksi"), segmentasi mikro membungkus batas pelindung (*firewall*) di sekitar **setiap mesin virtual (VM) secara individual**.

4.2 East-West vs North-South Traffic

Untuk memahami arsitektur *Data Center* modern, *Security Engineer* harus fasih dengan terminologi arah lalu lintas:

- **North-South Traffic (Utara-Selatan):** Lalu lintas yang keluar-masuk pusat data menuju klien internet (pengguna). Ini adalah lalu lintas yang dijaga oleh WAF (*Web Application Firewall*), NGFW, dan ZTNA.
- **East-West Traffic (Timur-Barat):** Lalu lintas antara peladen ke peladen di dalam pusat data yang sama (misal: komunikasi dari peladen *Web* Node 1 ke *Database* Node A).

Lebih dari 70% lalu lintas di dalam *Data Center* adalah *East-West*. Karena *Firewall* Perimeter tradisional diletakkan di tepi Utara-Selatan, ia sama sekali buta terhadap infeksi yang menyebar secara Timur-Barat. Implementasi *Zero Trust* mewajibkan proteksi agresif pada sumbu Timur-Barat ini melalui alat segmentasi khusus (seperti Illumio atau Cisco Secure Workload).

4.3 Host-Based Firewalls Terpusat

Menerapkan segmentasi mikro fisik menggunakan perangkat keras *switch/firewall* adalah hal yang mustahil (butuh terlalu banyak *hardware* dan pengaturan *routing* yang rumit). Solusi teknisnya adalah memanfaatkan **Host-Based Firewall** bawaan (seperti Windows Firewall atau `iptables` di Linux).

Perusahaan menginstal Agen Segmentasi pada setiap peladen. Agen ini tidak menyaring paket (yang akan memperlambat CPU), ia bertugas menerima kebijakan dari *Control Plane* sentral, lalu mengonversi kebijakan bisnis tersebut menjadi aturan `iptables` (atau Windows Firewall) lokal pada *OS* peladen tersebut.

> **Contoh Kebijakan ZTA Timur-Barat:**
> *"Server Web (Tag: Prod-Web) hanya diizinkan berkomunikasi TCP Port 3306 ke Server Database (Tag: Prod-DB)."*
>
> Jika *Server Web* diretas dan peretas mencoba melakukan PING atau koneksi RDP (Port 3389) ke *Server Database*, koneksi itu akan dijatuhkan (*Drop*) langsung oleh kartu jaringan OS (*Network Interface Card* / NIC) *Database*, meskipun mereka berada di *subnet* dan VLAN yang sama.

4.4 Software Defined Perimeter (SDP)

Konsep mikro-segmentasi sangat erat kaitannya dengan **Software Defined Perimeter (SDP)**. Alih-alih mengandalkan VLAN IP tradisional yang statis dan sangat sulit dipelihara (harus mengganti konfigurasi kabel/switch), SDP mendefinisikan batas secara perangkat lunak (*Software*).

Dalam SDP, identitas peladen tidak dilihat dari IP-nya, melainkan dari **Tag/Label Kriptografik**-nya. Saat arsitek *Cloud* memindahkan peladen dari AWS (IP: 10.x.x) ke Azure (IP: 172.x.x), *firewall* tradisional akan rusak karena bergantung pada daftar IP.

Dalam arsitektur ZTA (SDP), aturan ditulis tanpa IP: `ALLOW App=Frontend TO App=Backend PORT=8080`. Sistem agen secara dinamis dan otomatis memperbarui nilai IP *backend* (*resolving*) secara *real-time* kapan pun *server* tersebut bermigrasi di lingkungan multi-cloud, menjamin *Zero-Downtime Security*.

4.5 Kepercayaan Workload-to-Workload

Di *Zero Trust*, beban kerja mesin (*Machine Workloads*)—seperti *Cron Jobs*, API internal, atau layanan *Microservices*—juga dianggap sebagai "Entitas" yang wajib memiliki **Identitas**. *Machine-to-Machine* (M2M) tidak bisa lagi sekadar saling percaya karena berada dalam jaringan yang sama.

Peladen tidak menggunakan *Username* dan *Password* seperti manusia. Mereka melakukan autentikasi ke *Service Mesh* atau IdP menggunakan **Mutual TLS (mTLS)** dan Sertifikat X.509 berumur pendek (*Short-Lived Certificates*).

Jika sebuah *Microservice* penagihan (*Billing Service*) perlu menarik data dari *Microservice* Pengguna (*User Service*), ia mempresentasikan sertifikatnya. *Service* Pengguna memvalidasi sertifikat tersebut. Dengan mTLS, identitas klien dan server sama-sama divalidasi, dan koneksinya dienkripsi secara mandiri.



BAGIAN V

Visibilitas SOC &
Otomatisasi Deteksi ZTA

BAB 5: VISIBILITAS SOC & SOAR

5.1 Titik Buta (Blind Spots) Baru di Era ZTA

Transisi menuju arsitektur yang tidak memercayai perimeter membuat metode *Security Operations Center* (SOC) tradisional menjadi usang. Jika Anda adalah analis L1 yang hanya menatap peringatan *Firewall* (IDS/IPS) di gerbang masuk utama, Anda kini kehilangan 80% visibilitas lalu lintas korporat.

Mengapa? Karena lalu lintas pekerja jarak jauh (*Remote Workers*) tidak lagi melewati rute kembali ke kantor utama (*Backhauling*). Karyawan di rumah mengakses aplikasi *SaaS* (seperti Slack, AWS, M365) langsung melalui internet rumah mereka. Data tersebut tidak akan pernah menyentuh perangkat Cisco/Palo Alto fisik di *Data Center* perusahaan.

Untuk bertahan, *Detection Engineer* harus mengalihkan sumber pakan (*Ingest Pipeline*) SIEM (Splunk/Elastic) mereka. Anda harus mengintegrasikan *API Log* langsung dari penyedia *Cloud Identity* dan platform penyedia ZTNA.

5.2 SIEM Ingestion untuk Identity Logs

Dalam *Zero Trust*, pilar utama investigasi forensik adalah **Log Identitas** (misal: Azure AD *Sign-In Logs* atau Okta *System Logs*). Log ini mengandung telemetri tingkat emas bagi *Threat Hunters*.

Saat log identitas ditarik ke dalam SIEM, pastikan *parser* (seperti ECS di Elastic) memetakan medan (*fields*) berikut dengan presisi tinggi:

- `user.name` / `user.email`
- `source.ip` (IP asal permintaan *login*)
- `network.location` / `geo.country_name`
- `device.id` (Menunjukkan apakah ini PC kantor atau BYOD)
- `event.outcome` (SUCCESS / FAILURE)
- `authentication.type` (MFA, SSO, Legacy Auth)

Dengan medan yang dinormalisasi ini, analis SOC dapat menyatukan kepingan *Puzzle* insiden yang dimulai dari serangan Phishing M365 hingga akses VPN ZTNA menggunakan satu *Dashboard* grafis.

5.3 KQL: Mendeteksi MFA Fatigue Attack

Ancaman terbesar bagi ZTA berbasis MFA biasa adalah *MFA Fatigue* atau *Bombing*. Peretas mencoba *login* berulang kali (memiliki sandi yang benar) hingga mengirim puluhan notifikasi *Approve/Deny* ke ponsel pengguna di tengah malam.

```
/* SIEM KQL: Deteksi MFA Fatigue (Brute Force MFA Denials) */ sequence by user.email with maxspan=10m
[authentication where event.action == "mfa_challenge" and event.outcome == "failure" and reason ==
"user_denied" count=3] [authentication where event.action == "mfa_challenge" and event.outcome ==
"success"]
```

Aturan KQL/EQL *Stateful* ini mendeteksi urutan yang tidak alami: Seorang pengguna secara manual menekan "TOLAK" pada notifikasi MFA sebanyak 3 kali berturut-turut, namun pada percobaan ke-4 akhirnya "BERHASIL/DISETUJUI". Ini hampir pasti merupakan indikasi *MFA Fatigue* di mana pengguna akhirnya menyerah. *Severity* harus diatur ke tingkat **CRITICAL**.

5.4 KQL: Mendeteksi Session Token Theft

Jika peretas mengekstrak kuki (*Cookie/Token*) dari peramban, tidak ada log *login gagal* yang tercatat (karena mereka *bypass* fase kata sandi). Mereka sekadar menyajikan tiket sesi valid ke *Gateway*. Kita menangkap pencurian ini dengan mendeteksi anomali jaringan pada sesi yang sudah berlangsung (*Established Session*).

```
/* KQL: Deteksi perpindahan IP secara drastis dalam satu sesi (Token Hijack) */ event.dataset: "azure_ad.audit" AND event.action: "Suspicious_Session_IP_Change" OR ( sequence by user.session_id with maxspan=30m [network where source.geo.country_iso_code == "ID"] [network where source.geo.country_iso_code != "ID"] )
```

Dengan mengunci pada pengidentifikasi sesi logis (`user.session_id`), sistem akan meneriaki perpindahan negara. Jika satu *ID Sesi* (Cookie yang sama) digunakan di Indonesia pada menit ke-10, lalu digunakan di Belanda pada menit ke-20 tanpa adanya proses *login ulang*, ini adalah bukti definitif dari **Token Hijacking** (AiTM).

5.5 Continuous Evaluation Mechanism

Evaluasi *Zero Trust* tidak boleh berhenti di pintu masuk. Fitur kunci untuk mencapai kematangan (*Maturity*) ZTA adalah **Continuous Access Evaluation (CAE)**. Teknologi ini menciptakan jembatan dua arah (*bi-directional*) antara penyedia ZTNA/Awan dan mesin IAM pusat.

Bayangkan Anda sedang *download* fail berukuran 5 GB dari *Sharepoint*. Autentikasi Anda sejam lalu sah (Skor EDR Anda 100). Tiba-tiba, Anda mengunduh sampel uji *malware* yang ceroboh ke laptop Anda. EDR Anda berbunyi.

Dalam sistem ZTA statis kuno, unduhan 5 GB Anda akan terus berjalan karena *Token* sesi Anda masih berlaku selama 8 jam. Dalam sistem CAE modern, EDR memberikan sinyal kepada mesin *Identity* yang segera merobek (*revoke*) sertifikat *Token Sharepoint* saat itu juga. Pengunduhan dibatalkan di tengah jalan, terpotong secara waktu nyata (*Real-Time Session Termination*).

5.6 SOAR: Otomatisasi Session Revocation

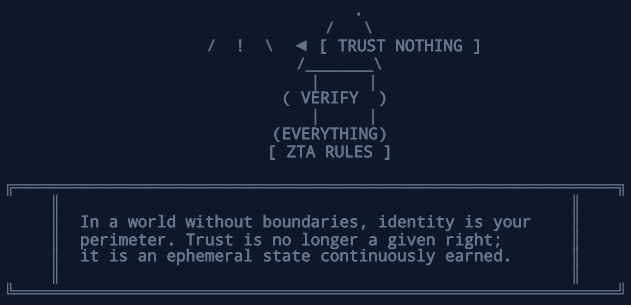
Kecepatan pemutusan sesi dalam ZTA sering kali membutuhkan orkestrasi **Security Orchestration, Automation, and Response (SOAR)** milik tim SOC, terutama jika perusahaan menggunakan produk dari berbagai vendor (*Multi-Vendor Stack*).

```
[ SIEM Alert: Token Hijacking Terdeteksi ]
                  |
                  ▼
[ SOAR Node: Trigger Okta API POST ]
  Headers: Authorization Bearer [API_TOKEN]
  URL: /api/v1/users/{user_id}/sessions
  Action: DELETE (Hancurkan sesi lokal Okta)
                  |
                  ▼
[ SOAR Node: Trigger AWS IAM API ]
  Action: RevokeActiveSessions
  (Hancurkan akses kredensial AWS CLI sementara)
                  |
                  ▼
[ SOAR Node: Isolasi Perangkat via EDR API ]
  Action: Network Containment (Host Isolation)
```

Melalui antarmuka visual *Playbook* di sistem SOAR (seperti Cortex XSOAR atau Splunk Phantom), analis merakit rantai isolasi masif. Saat *MFA Fatigue* terdeteksi, SOAR akan mengunci pengguna dari Okta, memutus koneksi terminal komputasi *Cloud* AWS, dan mengarantina *laptop* EDR-nya dalam 3 detik tanpa intervensi manusia.

GLOSARIUM ISTILAH ZTA (A-N)

TERMINOLOGI	DEFINISI ARSITEKTURAL
Assume Breach	Filosofi dasar ZTA yang merancang sistem perlindungan dengan anggapan bahwa peretas atau penyusup lokal sudah bersemayam di dalam jaringan.
Control Plane	Jalur komando logis yang terpisah (*Out-of-band*) tempat *Policy Engine* mengevaluasi identitas sebelum merutekan akses ke sistem aplikasi sebenarnya.
Dark Cloud	Kondisi di mana aplikasi disembunyikan menggunakan *Reverse Proxy ZTNA* sehingga tidak memiliki *IP Public Listener* (tak terlihat dari pindaian internet).
FIDO2 / WebAuthn	Standar autentikasi modern yang menggunakan kriptografi asimetris (*Hardware Security Key*) yang tahan (*resistant*) terhadap serangan Phishing / AiTM.
Lateral Movement	Taktik serangan di mana peretas bergerak miring dari satu peladen (rendah keamanan) ke peladen lain di *Subnet/VLAN* yang sama (seperti Server *Database*).
Micro-Segmentation	Membatasi area jaringan sekecil mungkin hingga ke tingkat satu beban kerja (VM/*Container*) menggunakan *firewall* berbasis *host*.



> In a world without boundaries, identity is your perimeter. Trust is no longer a given right; it is an ephemeral state continuously earned.

© 2026 All rights reserved. SOC Training & Reference Material.